TAREA DUAL
SEGURIDAD Y ALTA DISPONIBILIDAD

Sergio Villegas
2 ASIR

Contenido

Bloque 1: Estrategia y Perímetro de Seguridad 2
1.1. La Triada de la Seguridad (RA1.a) 2
1.2. Seguridad Física vs. Lógica (RA1.b) 3
1.3. Protección Perimetral (RA1.h) 3
Bloque 2: Vulnerabilidades y Factor Humano 4
2.1. Gestión de Vulnerabilidades (RA1.c) 4
2.2. Ingeniería Social (RA1.d) 4
2.3. Políticas de Contraseñas (RA1.e) 4
Bloque 3: Tecnologías de Protección y Respuesta 5
3.1. Sistemas Biométricos (RA1.f) 5
3.2. Criptografía Aplicada (RA1.g) 5
3.3. Análisis Forense e Incidentes (RA1.i) 6

Memoria Técnica: SAD en el Entorno de Prácticas

Extensión máxima: 5 páginas (contando enunciado)

Objetivo: Analizar la implementación real de las políticas de seguridad en un entorno profesional y contrastarlas con los conocimientos teóricos adquiridos.

Instrucciones

Durante tu estancia en la empresa, deberás completar este documento analizando los puntos que se detallan a continuación.

- **Si el punto se aplica en tu empresa:** Describe cómo lo hacen (herramientas, protocolos, software, etc.).
- **Si el punto NO se aplica:** Elabora una **propuesta técnica** detallada sobre cómo crees que debería implementarse para mejorar la seguridad de tu centro de prácticas.

Bloque 1: Estrategia y Perímetro de Seguridad

1.1. La Triada de la Seguridad (RA1.a)

Describe cómo la empresa garantiza los tres pilares fundamentales de la información:

- **Confidencialidad:** ¿Quién accede a qué?

Para mantener la confidencialidad de la empresa, vamos crear nombres ficticios dentro del departamento IT: Perro, Gato, Hiena y Koala

Cámaras de seguridad:	**Responsable**: GTO. **Encargado**: Jefe del departamento IT. **Delegado**: Trabajador “Perro” del departamento IT y trabajador “Jirafa” del departamento de Flota.
Servidores principales:	Empresas externas, “Koala” como responsable, “Hiena” y eventualmente “Gato”.
Controles de acceso:	Encargado: “Hiena”.
Servidores secundarios:	Todos los del departamento IT (salvo becarios).
Bases de datos (introducción de datos):	Prácticamente todas las empresas (con permisos por roles).

- **Integridad:** ¿Cómo evitan que los datos sean alterados sin permiso?
    - Regla del permiso mínimo
    - Registro de logs
    - Sistema de alertas por tráfico de datos masivo
    - Certificados digitales
    - Firmas en correos electrónicos (esta no es 100% fiable por si sola puesto que se puede replicar sin ser de la propia empresa).
- **Disponibilidad:** ¿Qué medidas hay para que el sistema no pare (Backups, SAIs, etc.)?
    - Sistema de alertas por tráfico de datos masivo
    - Sistema de monitorización
    - Backups periódicos
    - SAIs (Hasta dónde yo sé, aplica hasta en los equipos de los trabajadores).

1.2. Seguridad Física vs. Lógica (RA1.b)

Identifica las diferentes medidas de seguridad que encuentras en el centro de trabajo:

- **Física:** Medidas de acceso al CPD, cámaras, cerraduras, protección contra incendios…
    - En todas las puertas importantes y departamentos tienen puertas, a las cuales solo puedes acceder si tienes la tarjeta de la empresa. Para los CPDs, el departamento de informática puede decidir quién o no puede entrar.
    - Cámaras en casi todos los pasillos y departamentos (en ciertos departamentos no).
    - Tienen un sistema de detección de incendios con sus respectivos sistemas automáticos de extinción de incendios y extintores.
- **Lógica:** Antivirus, firewalls, permisos de usuario, segmentación de redes.
    - Antivirus corporativo.
    - Permisos por usuarios y grupos mediante Active Directory.
    - VLANs y filtrados MAC para la conexión de equipos a la red. Por ejemplo, yo mi portátil personal no puedo conectarlo a la red cableada.
    - Detección de phishing y correos spam.
    - Firewalls configurados.

1.3. Protección Perimetral (RA1.h)

Analiza el plan de protección frente a redes públicas (Internet). ¿Existe un firewall físico? ¿Se utilizan zonas desmilitarizadas (DMZ)? ¿Cómo se gestionan las conexiones externas?

- A ese plan no tenemos acceso como tal, pero esa seguridad es mencionada con los puntos nombrados en el apartado 1.2. Seguridad Física vs. Lógica (RA1.b).
- Desconozco si tienen un firewall físico.
- Desconozco si tienen zonas DMZ.
- Sobre las conexiones externas, usan la VPN llamada CheckPoint.

Bloque 2: Vulnerabilidades y Factor Humano

2.1. Gestión de Vulnerabilidades (RA1.c)

- Clasifica las principales vulnerabilidades que detectes en el sistema de la empresa según su origen (software desactualizado, falta de parches, hardware antiguo, configuración incorrecta).

Aunque seguro que hay muchas más, no he podido identificar ninguna más, la empresa está bastante bien securizada.

Windows 10

Actualmente hay ciertos equipos en la empresa con Windows 10, y como ya sabemos bien, Windows 10 ya no es seguro actualmente.

Diariamente trabajamos en seguir actualizándolos (ya quedan pocos) para solucionar esas vulnerabilidades disponibles.

2.2. Ingeniería Social (RA1.d)

- ¿Ha sufrido la empresa algún intento de phishing o fraude? ¿Existe concienciación entre los empleados? Describe qué medidas se toman para evitar que el personal caiga en engaños informáticos.

El único caso que he escuchado en la empresa era una conversación que tuvo el trabajador Hiena con otra chica de otro departamento, en la cual, la chica le pedía a la Hiena que le desbloquease el correo bloqueado por el filtro anti spam.
Me pareció entender que el trabajador Hiena le comentaba a la chica que el correo parecía sospechoso y que podría ser un intento de phishing, pero que, si ella estaba esperando ese correo concretamente, se lo desbloquearía.

Concienciación si existe puesto que existe una normativa Europea que obliga a GTO a tener a un 100% de los trabajadores formados en materia de ciberseguridad.

Las medidas usadas son, además de la concienciación, las que he nombrado anteriormente en el apartado 1.2. Seguridad Física vs. Lógica (RA1.b).

2.3. Políticas de Contraseñas (RA1.e)

Describe la normativa interna: longitud mínima, caducidad, uso de Doble Factor de Autenticación (2FA) y si se utiliza algún gestor de contraseñas corporativo.

- Políticas de contraseñas mediante AD
  - Cambios periódicos
  - Longitud mínima
  - Uso de caracteres complejos
- Para el inicio de sesión en Microsoft tienen un 2FA
- No se hace uso de Gestor de contraseñas.

Bloque 3: Tecnologías de Protección y Respuesta

3.1. Sistemas Biométricos (RA1.f)

- ¿Se utiliza la biometría (huella, reconocimiento facial) para el acceso a las instalaciones o a los dispositivos? Si no es así, justifica si sería ventajoso implantarlo en algún área específica.

Se usaba anteriormente, pero debido a normativas Europeas (concretamente el artículo 9.1 del reglamento (UE) 2016/ 679) lo tienen desactivado.

El método que se usa actualmente es el lector de tarjetas.

No sería ventajoso implantarlo porque, en caso de que lo montes, llegaría la AEPD y le metería una buena multa a la empresa.

El único caso en el cual si podría usarse sería si el uso de biometría fuera estrictamente necesario y bajo muchos controles y restricciones.

3.2. Criptografía Aplicada (RA1.g)

Identifica el uso de la criptografía en:

- **Almacenamiento:** ¿Se cifran los discos duros o bases de datos?

No son cifrados porque en caso de necesitar rescatar datos o resolución de problemas, impide y dificulta demasiado la labor de hacerlo.

- **Transmisión:** ¿Qué protocolos se usan para el envío de datos (HTTPS, VPN, SSH, SFTP)?

Para el envío de datos utilizan:

RDP: TCP 3389

SMB 3.0 (Para Unidades en Red): TCP 445

AnyDesk: TCP 80, 443, 6568

Impresión IPP: Puerto 9100

Además, usan los típicos (22, 443, 587, 993…)

3.3. Análisis Forense e Incidentes (RA1.i)

- En caso de un ataque o brecha de seguridad, ¿conoces las fases que sigue la empresa? (Identificación, preservación de evidencias, análisis de logs, recuperación). Si no tienen un protocolo, diseña un esquema básico de respuesta ante incidentes para ellos.

Por lo que nos contaron en la charla de ciberseguridad, depende del ataque, pero lo que llegamos a entender, los pasos serían mas o menos los siguientes:

1. Desconexión de los equipos a la red. (Tirar de los cables de red)
2. Contacto con organismos públicos como INCIBE
3. Identificación del malware
    a. Revisión exhaustiva del “paciente 0”
    b. Revisión de logs
4. Implantación de medidas aconsejadas o restauración de backups.